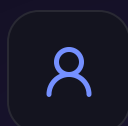


• PENTEST LIVE • LECTURE SEULE

Atelier Pentest live

eRezo

Architecture IA



Maxime Nicole

EI KodeSaaS

Un pentest sans autorisation est un **délit**.

🔗 CODE PÉNAL · ART. 323-1 S.

Accès et maintien frauduleux dans un système : jusqu'à **plusieurs années de prison** et de lourdes **amendes**.

🛡 POURQUOI C'EST LÉGAL ICI

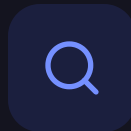
Uniquement parce que **KodeSaaS possède eRezo** et vous **autorise**, dans un cadre strictement pédagogique.

🔒 **Règle d'or** — jamais sur un site tiers sans autorisation écrite.



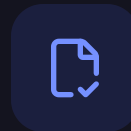
En binôme, auditez **erezo.fr**

Deux personnes maximum. Un objectif : trouver un maximum de failles.



Trouver

Cherchez le maximum de failles sur l'application.



Prouver

Une faille ne compte que si vous la démontrez.



Prioriser

Classez - les par impact réel : P0, P1, P2.

👁️ Vous ne cassez rien : vous cherchez, vous testez **en lecture seule**, vous documentez.

Ce qui est autorisé, ce qui ne l'est pas

✓ AUTORISÉ

- ✓ Reconnaissance
- ✓ Navigation authentifiée
- ✓ Manipuler des paramètres en lecture seule
- ✓ Analyser en-têtes & cookies

⊘ INTERDIT

- ✗ Toute destruction ou modification
- ✗ Brute-force
- ✗ Déni de service (DoS)
- ✗ Exfiltrer de vraies données · sortir d'erezo.fr

🔗 Données réelles croisées → **anonymisez.**

ÉTAPE 1

01

Créez votre compte de test sur erezo.fr



Votre point de départ = un **utilisateur authentifié lambda**.

Cinq phases, dans l'ordre

1  Reconnaissance

2  Cartographie authentifiée

3  Contrôle d'accès — IDOR

LE PLUS IMPORTANT

4  En-têtes & configuration

5  Injection & entrées

 IDOR · Insecure Direct Object Reference — accéder aux données d'un autre utilisateur en modifiant un identifiant (URL, paramètre, requête) que le serveur ne revérifie pas.

Ce n'est pas l'outil, c'est la demande



Installer la skill **ne suffit pas** à faire un pentest. C'est votre façon de **demander** (le prompt) qui fait sortir les vraies infos.

Prompt vague → résultat vague

Prompt précis, cadré → trouve, prouve, priorise

INSTALLER L'OUTIL

Option A Claude Code

```
/plugin marketplace add trilwu/secskills  
/plugin install trilwu/secskills  
/plugin enable secskills
```

Option B Autre IA Cursor · ChatGPT · Claude.ai · Gemini

Collez le **prompt de pentest** fourni (la « SOP ») au début de la conversation.

>_ PUIS DEMANDEZ BIEN

« Lance un pentest en **LECTURE SEULE** sur mon compte de test erezo.fr. Procède par phases (recon → cartographie → contrôle d'accès → en-têtes → injection). Pour chaque faille : **endpoint, preuve, impact, priorité P0/P1/P2**. N'invente rien : si tu n'es pas sûr, dis comment vérifier. »

ⓘ Rappel — l'IA propose, **VOUS vérifiez**. Une faille non reproduite ne compte pas.



Les dix risques à chercher

A01 → A05

A01



Contrôle d'accès défaillant

IDOR, escalade de privilèges

DÉTAILLÉ SLIDE 06

A02



Défaillances cryptographiques

Chiffrement faible ou absent

A03



Injection

SQL, NoSQL, OS, LDAP

A04



Conception non sécurisée

Défauts de conception (insecure design)

A05



Mauvaise configuration

Réglages par défaut, debug en prod



Les dix risques à chercher

A06 → A10

A06



Composants vulnérables

Dépendances obsolètes / CVE connues

A07



Défaillances d'authentification

Login contournable, sessions faibles

A08



Manque d'intégrité (logiciel / données)

Mises à jour non signées, désérialisation

A09



Défaut de journalisation & supervision

On ne détecte pas l'attaque

A10



SSRF

Le serveur est manipulé pour requêter en interne



La grille de findings

FAILLE	PREUVE	IMPACT	PRIORITÉ
Nature de la faille	Capture · requête · étapes	Ce qu'un attaquant obtient	P0 · P1 · P2
...	...	...	...

P0 Critique

P1 Important

P2 À durcir

✔ Une preuve = une faille qui compte.



Présentez vos 2-3 meilleures failles.

Qui a trouvé les P0 ?



github.com/mnicole90/formation-architecture-ia

 Rappel final — anonymisez tout, et **jamais hors autorisation.**



Le bug bounty

Pentester légalement — et être payé pour ça.

🎯 LE PRINCIPE

Une entreprise publie un **périmètre autorisé (scope)** et des règles. Vous trouvez une faille valide → vous êtes **récompensé**, souvent en argent.

📁 VDP

Vulnerability Disclosure Program — le même cadre, sans prime.

OÙ TROUVER DES CIBLES AUTORISÉES

🌐 **YesWeHack** · FR/EU
yeswehack.com/programs

📁 **FireBounty** · agrégateur
firebounty.com

🐞 **Bugcrowd**
bugcrowd.com/bug-bounty-list

🛡️ **disclose.io** · safe harbor
disclose.io

🔒 Règle d'or inchangée — on ne teste que ce qui est dans le scope. Tout le reste = **délit**.

« L'IA ne fait pas de vous un hacker. Elle rend un **bon auditeur redoutable.** »



L'IA accélère le travail, **jamais le jugement.**



Vous êtes architecte & reviewer — l'IA propose, **VOUS vérifiez.**



Piloter l'outil sans compétence ne produit que du **bruit.**



Jamais hors autorisation, jamais une faille non vérifiée. La **compétence d'abord, l'outil ensuite.**